

AEGIS SECURITY

EXTERNAL PENETRATION TEST REPORT

PTES & NIST SP 800-115 Aligned

Target(s):	http://www.dvwa.co.uk/
Report Date:	2026-04-24
Assessment Type:	External Black-Box Penetration Test
Standard:	PTES / NIST SP 800-115 / OWASP Testing Guide v4.2
Phases:	Passive, Active, Vuln
Classification:	CONFIDENTIAL — Authorized Recipients Only

OVERALL RISK POSTURE: ELEVATED

CRITICAL	HIGH	MEDIUM	LOW	OPEN PORTS	SUBDOMAINS
0	2	5	7	8	1

CONFIDENTIAL — This document contains sensitive security findings. Distribution strictly limited to authorized personnel.

TABLE OF CONTENTS		
1.	Executive Summary	Risk overview, posture assessment, business impact
2.	Scope & Methodology	Targets, rules of engagement, PTES phases, CVSS scale
3.	Attack Surface Overview	Subdomains, open ports, SSL/TLS, technology fingerprint
4.	Technical Findings	Detailed vulnerabilities with CVSS, PoC, and evidence
5.	Remediation & Recommendations	Prioritized fixes aligned with CIS Controls
6.	Strategic Security Roadmap	90-day plan for security improvement
7.	Appendices	Tools used, DNS records, standards references

1. EXECUTIVE SUMMARY

Aegis Security conducted an external penetration test against **http://www.dvwa.co.uk/** on **2026-04-24** following PTES and NIST SP 800-115. Phases executed: **Passive, Active, Vuln**.

Overall Security Posture: ELEVATED

Severity	Count	CVSS Range	Business Impact
Critical	0	9.0–10.0	Immediate exploitation; data breach / RCE risk
High	2	7.0–8.9	Significant impact; exploitable with moderate effort
Medium	5	4.0–6.9	Conditional exploit; may chain with other findings
Low	7	0.1–3.9	Minimal direct impact; defence-in-depth improvement

Business Impact

- Potential unauthorized access to sensitive systems and customer data
- Risk of data exfiltration impacting confidentiality and compliance (GDPR, PCI-DSS)
- Reputational and financial impact if vulnerabilities are exploited externally

2. SCOPE & METHODOLOGY

3. ATTACK SURFACE OVERVIEW

Subdomain Enumeration — 1 Discovered

■ www.dvwa.co.uk		
--	--	--

Port Scan Results — 8 Services Identified

Port	Service	Product / Version	Risk
22	ssh	OpenSSH 8.9	■ REVIEW
80	http	nginx 1.22	■ REVIEW
443	https	nginx 1.22	■ REVIEW
3306	mysql	MySQL 8.0	■ REVIEW
5900	vnc	RealVNC 5.3	■ REVIEW
8080	http-proxy		■ REVIEW
8443	https-alt		OK
9090	zeus-admin		OK

SSL/TLS Certificate

Issuer:	—
Expires:	—
Days Left:	235
Protocol:	—
Cipher:	—

Web Technology & Security Headers

URL:	http://www.dvwa.co.uk
------	-----------------------

Server:	nginx/1.22
Tech Stack:	PHP, nginx
Missing Security Headers:	Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options

4. TECHNICAL FINDINGS

14 total findings: 0 Critical · 2 High · 5 Medium · 7 Low.

URL / System:	http://www.dvwa.co.uk/
Source:	Nmap
Description:	Port 3306 (mysql) is open and exposed externally. Service: MySQL 8.0. Publicly exposed MySQL services increase the attack surface significantly.
Recommended Fix:	If MySQL is not required externally, restrict access via firewall rules. If needed, enforce strong authentication and encryption.

URL / System:	http://www.dvwa.co.uk/
Source:	Nmap
Description:	Port 5900 (vnc) is open and exposed externally. Service: RealVNC 5.3. Publicly exposed VNC services increase the attack surface significantly.
Recommended Fix:	If VNC is not required externally, restrict access via firewall rules. If needed, enforce strong authentication and encryption.

URL / System:	http://www.dvwa.co.uk/
Source:	Nmap
Description:	Port 22 (ssh) is open and exposed externally. Service: OpenSSH 8.9. Publicly exposed SSH services increase the attack surface significantly.
Recommended Fix:	If SSH is not required externally, restrict access via firewall rules. If needed, enforce strong authentication and encryption.

URL / System:	http://www.dvwa.co.uk
Source:	HTTPX
Description:	The following recommended security headers are absent: Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options. Missing headers can allow clickjacking, MIME sniffing, and XSS attacks.
Recommended Fix:	Add the following HTTP response headers: Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options

URL / System:	http://www.dvwa.co.uk/login.php
Source:	Feroxbuster
Description:	Accessible path discovered (HTTP 200): 200 GET http://www.dvwa.co.uk/login.php
Recommended Fix:	Review exposed path and restrict access if unnecessary.

URL / System:	http://www.dvwa.co.uk/setup.php
Source:	Feroxbuster
Description:	Accessible path discovered (HTTP 200): 200 GET http://www.dvwa.co.uk/setup.php
Recommended Fix:	Review exposed path and restrict access if unnecessary.

URL / System:	http://www.dvwa.co.uk/phpinfo.php
Source:	Feroxbuster
Description:	Accessible path discovered (HTTP 200): 200 GET http://www.dvwa.co.uk/phpinfo.php
Recommended Fix:	Review exposed path and restrict access if unnecessary.

URL / System:	http://www.dvwa.co.uk/
Source:	Nmap
Description:	Port 80 (http) is open and exposed externally. Service: nginx 1.22. Publicly exposed HTTP services increase the attack surface significantly.
Recommended Fix:	If HTTP is not required externally, restrict access via firewall rules. If needed, enforce strong authentication and encryption.

URL / System:	http://www.dvwa.co.uk/
Source:	Nmap
Description:	Port 443 (https) is open and exposed externally. Service: nginx 1.22. Publicly exposed HTTPS services increase the attack surface significantly.
Recommended Fix:	If HTTPS is not required externally, restrict access via firewall rules. If needed, enforce strong authentication and encryption.

URL / System:	http://www.dvwa.co.uk/
Source:	Nmap
Description:	Port 8080 (http-proxy) is open and exposed externally. Service: unknown. Publicly exposed HTTP-Alt services increase the attack surface significantly.
Recommended Fix:	If HTTP-Alt is not required externally, restrict access via firewall rules. If needed, enforce strong authentication and encryption.

URL / System:	http://www.dvwa.co.uk/
Source:	Nmap
Description:	Port 8443 (https-alt) is open and exposed externally. Service: unknown. Publicly exposed HTTPS-Alt services increase the attack surface significantly.
Recommended Fix:	If HTTPS-Alt is not required externally, restrict access via firewall rules. If needed, enforce strong authentication and encryption.

URL / System:	http://www.dvwa.co.uk/
Source:	Nmap
Description:	Port 9090 is open with service: zeus-admin.
Recommended Fix:	Review whether this service needs external exposure.

URL / System:	http://www.dvwa.co.uk/images/
Source:	Feroxbuster
Description:	Accessible path discovered (HTTP 301): 301 GET http://www.dvwa.co.uk/images/
Recommended Fix:	Review exposed path and restrict access if unnecessary.

URL / System:	http://www.dvwa.co.uk/.htaccess
Source:	Feroxbuster
Description:	Accessible path discovered (HTTP 403): 403 GET http://www.dvwa.co.uk/.htaccess
Recommended Fix:	Review exposed path and restrict access if unnecessary.

5. REMEDIATION & RECOMMENDATIONS

Remediation actions are prioritized by severity and aligned with CIS Critical Security Controls v8 and NIST SP 800-53 Rev 5.

PRIORITY 1 — IMMEDIATE (0–72 hours)

- Remediate all 0 Critical finding(s) without delay
- Apply interim mitigations: WAF rules, firewall ACLs for exposed critical services
- Enable enhanced logging and alerting on affected systems
- Brief senior stakeholders on highest-risk findings

PRIORITY 2 — SHORT TERM (72 hrs – 2 weeks)

- Remediate all 2 High severity findings
- Patch identified vulnerable software with vendor-supplied updates
- Enforce HTTPS everywhere; implement HSTS preloading
- Deploy missing security headers (CSP, X-Frame-Options, X-Content-Type-Options)

PRIORITY 3 — MEDIUM TERM (2–8 weeks)

- Remediate all 5 Medium severity findings
- Implement Web Application Firewall (WAF) on all external services
- Enforce TLS 1.2+ minimum; disable TLS 1.0/1.1 and weak ciphers
- Implement DMARC, DKIM, SPF DNS records if missing
- Review and restrict all non-essential exposed ports

PRIORITY 4 — LONG TERM (1–3 months)

- Establish a continuous vulnerability management programme
- Implement subdomain monitoring and takeover prevention
- Schedule next external penetration test (minimum: annually)
- Align security programme with ISO 27001 or SOC 2 Type II

6. STRATEGIC SECURITY ROADMAP

A structured 90-day plan for addressing findings and improving overall security posture.

Days 1–7	IMMEDIATE RESPONSE
• Confirm all critical findings and apply patches or interim controls
• Brief security team and stakeholders
• Initiate incident response if active exploitation suspected
Days 8–30	SHORT-TERM HARDENING
• Remediate High findings; verify all critical fixes
• Deploy security headers across all web properties
• Enforce TLS 1.2+ and disable weak protocols
Days 31–60	MEDIUM-TERM IMPROVEMENTS
• Address Medium findings; improve DNS security
• Review and restrict public-facing service exposure
• Conduct internal security awareness briefing
Days 61–90	LONG-TERM MATURITY
• Establish continuous scanning and vulnerability management
• Define security KPIs and monthly reporting cadence
• Schedule next penetration test and evaluate WAF deployment

7. APPENDICES

Appendix A: Tools & Versions

Tool	Version / Source	Purpose
WHOIS	python-whois / CLI	Domain registration, registrar, name servers
DNS	dig (BIND utils)	A/MX/NS/TXT/SOA record enumeration
SSL/TLS	Python ssl / crt.sh	Certificate validity, cipher suite analysis
Subfinder	projectdiscovery	Passive subdomain enumeration
Shodan	Shodan API	Exposed device intelligence, CVE cross-reference
Nmap	Nmap 7.x+	Full TCP port scan; service version detection
HTTPX	Custom module	HTTP fingerprinting, security header audit
Feroxbuster	feroxbuster	Directory and file discovery
Nuclei	projectdiscovery	CVE & misconfiguration template scanning
OWASP ZAP	ZAP 2.x+	Active web application scanning

Appendix B: References

PTES Penetration Testing Execution Standard http://www.pentest-standard.org/

NIST SP 800-115 Technical Guide to Information Security Testing https://csrc.nist.gov/publications/detail/sp/800-115/final

OWASP WSTG v4.2 OWASP Web Security Testing Guide https://owasp.org/www-project-web-security-testing-guide/

CIS Controls v8 CIS Critical Security Controls https://www.cisecurity.org/controls/

CVSS v3.1 Common Vulnerability Scoring System https://www.first.org/cvss/

MITRE ATT&CK Adversary Tactics, Techniques & Common Knowledge https://attack.mitre.org/